

Enterprise Compliance Policy

Data Protection

All customer PII must be encrypted at rest (AES-256) and in transit (TLS 1.3). Data retention is 7 years for financial records and 3 years for operational logs. GDPR and CCPA compliance is mandatory for all customer-facing systems.

Access Control

Role-based access control (RBAC) is enforced across all systems. Privileged access requires MFA and is reviewed quarterly. Shared credentials are strictly prohibited.

Incident Response

Security incidents must be reported within 1 hour of detection. The CISO must be notified for any breach affecting >100 records. Post-incident reviews are mandatory within 5 business days.

Audit Requirements

All system access is logged and retained for 12 months. Internal audits are conducted bi-annually. External audits annually.